

因为最近有任务需要搭建一些适合新手使用的靶场，所以收集了一下互联网常见的一些友好的新手渗透测试靶场。

分别是DVWA、Pikachu、SQLi-Labs、Upload-Labs、XSS-Labs。

// DVWA靶场

DVWA靶场是一个专门用于漏洞测试和练习的Web应用程序，旨在为安全专业人员和开发人员提供一个安全漏洞测试环境。

DVWA靶场包含了多种常见的Web应用程序漏洞，如SQL注入、跨站脚本攻击（XSS）、跨站请求伪造（CSRF）、文件包含、文件上传、不安全的验证码等。这些漏洞模拟了真实环境中可能遇到的安全威胁。针对每种漏洞类型，DVWA靶场提供了不同难度级别的测试场景，从低级别到高级别，适合不同技术水平的学习者进行挑战。低级别场景通常较为简单，适合初学者入门学习；而高级别场景则考验了用户在渗透测试和应用程序安全方面的深度技术掌握和思考能力。

DVWA靶场只需要配置./config/config.inc.php数据库地址用户名及密码就可以使用PHPStudy启动（记得将config.inc.php.dist文件的.dist后缀删掉）。

```
$_DVWA = array();
$_DVWA[ 'db_server' ]   = getenv('DB_SERVER') ?: '127.0.0.1';
$_DVWA[ 'db_database' ] = 'dvwa';
$_DVWA[ 'db_user' ]     = 'dvwa';
$_DVWA[ 'db_password' ] = 'p@ssw0rd';
$_DVWA[ 'db_port' ]     = '3306';
```

公众号·剥椒Muyou鱼头

使用默认密码admin/password登录。



Username

Password

Login

公众号·剥椒Muyou鱼头

选择Setup选项卡，可以百度一下标红报错怎么处理掉，然后初始化数据库就可以了。

Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

CSP Bypass

JavaScript

Authorisation Bypass

Open HTTP Redirect

Cryptography

DVWA Security

PHP Info

About

Logout

Database Setup

Click on the 'Create / Reset Database' button below to create or reset your database.
If you get an error make sure you have the correct user credentials in:
C:\phpStudy\PHPTutorial\WWW\DVWA\config\config.inc.php

If the database already exists, it will be cleared and the data will be reset.
You can also use this to reset the administrator credentials ("admin // password") at any stage.

Setup Check

Web Server SERVER_NAME:

Operating system: Windows

PHP version: 7.2.1
Versions of PHP below 7.3 may work but have known problems, please upgrade.

PHP function display_errors: Enabled
PHP function display_startup_errors: Enabled
PHP function allow_url_include: Enabled
PHP function allow_url_fopen: Enabled
PHP module gd: Installed
PHP module mysql: Installed
PHP module pdo_mysql: Installed

Backend database: MySQL/MariaDB
Database username: root
Database password: *****
Database database: dvwa
Database host: 127.0.0.1
Database port: 3306

reCAPTCHA key: Missing

Writable folder C:\phpStudy\PHPTutorial\WWW\DVWA\hackable\uploads\: Yes
Writable folder C:\phpStudy\PHPTutorial\WWW\DVWA\config: Yes

Status in red, indicate there will be an issue when trying to complete some modules.

If you see disabled on either allow_url_fopen or allow_url_include, set the following in your php.ini file and restart Apache.
allow_url_fopen = On
allow_url_include = On

These are only required for the file inclusion labs so unless you want to play with those, you can ignore them.

Create / Reset Database

公众号 · 剁椒Muyou鱼头

访问登录就可以了，建议新手选择模式为Low级别。



Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

CSP Bypass

JavaScript

Authorisation Bypass

Open HTTP Redirect

Cryptography

DVWA Security

PHP Info

About

Logout

Welcome to Damn Vulnerable Web Application!

Damn Vulnerable Web Application (DVWA) is a PHP/MySQL web application that is damn vulnerable. Its main goal is to be an aid for security professionals to test their skills and tools in a legal environment, help web developers better understand the processes of securing web applications and to aid both students & teachers to learn about web application security in a controlled class room environment.

The aim of DVWA is to practice some of the most common web vulnerabilities, with various levels of difficulty, with a simple straightforward interface.

General Instructions

It is up to the user how they approach DVWA. Either by working through every module at a fixed level, or selecting any module and working up to reach the highest level they can before moving onto the next one. There is not a fixed object to complete a module; however users should feel that they have successfully exploited the system as best as they possible could by using that particular vulnerability.

Please note, there are both documented and undocumented vulnerabilities with this software. This is intentional. You are encouraged to try and discover as many issues as possible.

There is a help button at the bottom of each page, which allows you to view hints & tips for that vulnerability. There are also additional links for further background reading, which relates to that security issue.

WARNING!

Damn Vulnerable Web Application is damn vulnerable! Do not upload it to your hosting provider's public html folder or any Internet facing servers, as they will be compromised. It is recommend using a virtual machine (such as [VirtualBox](#) or [VMware](#)), which is set to NAT networking mode. Inside a guest machine, you can download and install [XAMPP](#) for the web server and database.

Disclaimer

We do not take responsibility for the way in which any one uses this application (DVWA). We have made the purposes of the application clear and it should not be used maliciously. We have given warnings and taken measures to prevent users from installing DVWA on to live web servers. If your web server is compromised via an installation of DVWA it is not our responsibility it is the responsibility of the person/s who uploaded and installed it.

More Training Resources

DVWA aims to cover the most commonly seen vulnerabilities found in today's web applications. However there are plenty of other issues with web applications. Should you wish to explore any additional attack vectors, or want more difficult challenges, you may wish to look into the following other projects:

- [Mutillidae](#)
- [OWASP Vulnerable Web Applications Directory](#)

 公众号 · 剁椒Muyou鱼头

// Pikachu靶场

Pikachu靶场是一个专门为网络安全爱好者和学习者设计的Web安全靶场。靶场通过模拟真实的Web应用程序环境，提供了一系列漏洞和安全挑战，让用户可以在安全的环境中进行学习和测试。它旨在帮助用户学习和实践常见的Web安全漏洞和攻击手法，如SQL注入、XSS（跨站脚本攻击）、CSRF（跨站请求伪造）等。

Pikachu靶场需要配置./inc/config.inc.php数据库地址用户名及密码就可以使用PHPStudy启动。

config.inc.php - 記事本

文件(F) 編輯(E) 格式(O) 查看(V) 幫助(H)

<?php
//全局session_start
session_start();
//全局设置时区
date_default_timezone_set('Asia/Shanghai');
//全局设置默认字符
header('Content-type:text/html;charset=utf-8');
//定义数据库连接参数
define('DBHOST', '127.0.0.1');//将localhost或者127.0.0.1修改为数据库服务器的地址
define('DBUSER', 'root');//将root修改为连接mysql的用户名
define('DBPW', 'root');//将root修改为连接mysql的密码，如果改了还是连接不上，请先
define('DBNAME', 'pikachu');//自定义，建议不修改
define('DBPORT', '3306');//将3306修改为mysql的连接端口，默认tcp3306

?>

公众号 · 剁椒Muyou鱼头

然后需要访问install.php进行初始化数据库。

Pikachu 漏洞练习平台 pika-pika-

系统介绍

系统初始化安装

暴力破解

Cross-Site Scripting

CSRF

SQL-Inject

Setup guide:
第0步：请提前安装“mysql+php+中间件”的环境;
第1步：请根据实际环境修改inc/config.inc.php文件里面的参数;
第2步：点击“安装/初始化”按钮;

安装/初始化

公众号 · 剁椒Muyou鱼头

访问主页就可以愉快地玩耍了。

Pikachu 漏洞练习平台 pika-pika-

系统介绍

系统介绍

暴力破解

Cross-Site Scripting

CSRF

SQL-Inject

RCE

File Inclusion

Unsafe Filedownload

Unsafe Fileupload

Over Permission

SQL-Inject

PHP反序列化

XXE

URL重定向

SSRF

管理工具

Pikachu是一个带有漏洞的Web应用系统，在这里包含了常见的web安全漏洞。如果你是一个Web渗透测试学习人员且正发愁没有合适的靶场进行练习，那么Pikachu可能正合你意。

Pikachu上的漏洞类型列表如下：

- Burt Force(暴力破解漏洞)
- XSS(跨站脚本漏洞)
- CSRF(跨站请求伪造)
- SQL-Inject(SQL注入漏洞)
- RCE(远程命令/代码执行)
- Files Inclusion(文件包含漏洞)
- Unsafe file download(不安全的文件下载)
- Unsafe file uploads(不安全的文件上传)
- Over Permission(权限漏洞)
- ../(目录遍历)
- I can see your ABC(敏感信息泄露)
- PHP反序列化漏洞
- XXE(XML External Entity attack)
- 不安全的URL重定向
- SSRF(Server-Side Request Forgery)
- More...(敬请期待...有彩蛋)

管理工具里面提供了一个简单的xss管理后台，供你测试的漏洞和cookie~
后续会持续更新一些新的漏洞进来，也欢迎你提交漏洞案例给我，最新版本请关注pikachu

每类漏洞根据不同的情况又分别设计了不同的子类
同时，为了让这些漏洞更有趣一些，在Pikachu平台上为每个漏洞都设计了一些小的场景，点击漏洞页面右上角的“提示”可以查看帮助信息。

如何安装和使用

Pikachu使用世界上最好的语言PHP进行开发，数据库使用的是mysql，因此运行Pikachu你需要提前安装好“PHP+MYSQL+中间件（如apache,nginx等）”的基础环境。建议在你的测试环境直接使用一些集成软件来搭建这些基础环境，比如XAMP/PHPAMP等，作为一个安全的人应该不是什么事，接下来：
->将下载下来的pikachu文件上传到web服务器根目录下；
->根据实际环境修改inc/config.inc.php里面的数据库连接配置；
->访问http://x.x.x.x/pikachu，会有一个红色的热情提示“欢迎使用pikachu还没有初始化，点击进行初始化安装”，点击即可完成安装。

我为Pikachu创建了一个QQ群(532078894)，欢迎加进来和大家一起学习讨论。
如果阁下对Pikachu有什么建议或者想找我聊聊天可以发个邮件给我：1061321987@qq.com，谢谢。

切记
“少就是多，慢就是快”

公众号 · 剁椒Muyou鱼头

// SQLi-Labs靶场

SQLi-Labs是一个专门设计用于学习和测试SQL注入漏洞的开源靶场，它提供了一个包含多个具有不同漏洞类型和难度级别的Web应用程序的环境。通过在这个靶场中进行实践，用户可以更深入地了解SQL注入的原理、危害以及防范措施。

SQLi-Labs靶场需要配置sql-connections/db-creds.inc文件中的数据库地址用户名及密码就可以使用PHPStudy启动。

 db-creds.inc - 记事本

文件(F) 编辑(E) 格式(O) 查看(V) 帮助(H)

|<?php

```
//give your mysql connection username n password
$dbuser = 'root';
$dbpass = "";
$dbname = "security";
$host = 'localhost';
$dbname1 = "challenges";
```

?>

 公众号 · 剥椒Muyou鱼头

点击“Setup/reset Database”以创建数据库，创建表并填充数据。

SQLi-LABS Page-1 (Basic Challenges)

[Setup/reset Database for labs](#)

[Page-2 \(Advanced Injections\)](#)

[Page-3 \(Stacked Injections\)](#)

[Page-4 \(Challenges\)](#)

 公众号 · 剥椒Muyou鱼头

访问即可正常使用。



// Upload-Labs靶场

Upload-Labs靶场是一个专注于文件上传漏洞的模拟环境，它使用PHP语言编写，旨在帮助用户了解和学习文件上传漏洞的原理及防御技术。Upload-Labs靶场包含了多个关卡，每个关卡都模拟了不同的文件上传场景和漏洞类型。用户可以通过在这些关卡中进行实战演练，逐步掌握文件上传漏洞的攻击和防御技能。这些关卡涵盖了常见的文件上传漏洞类型，如文件名欺骗、文件类型欺骗、文件上传功能绕过等。【开箱既食】



// XSS-Labs靶场

XSS-Labs靶场是一个专注于跨站脚本攻击的安全测试平台。XSS-Labs靶场提供了多个不同的实验场景，每个场景都涵盖了不同类型的XSS漏洞，包括反射型、存储型和DOM型XSS等。这些场景模拟了真实环境中可能出现的XSS攻击场景，允许用户进行模拟和实践。【开箱既食】